نگهبان نامرئی لینوکس؛ SELinux

اصفهان لاگ – آبان ۱۴۰۵

$ Whoami



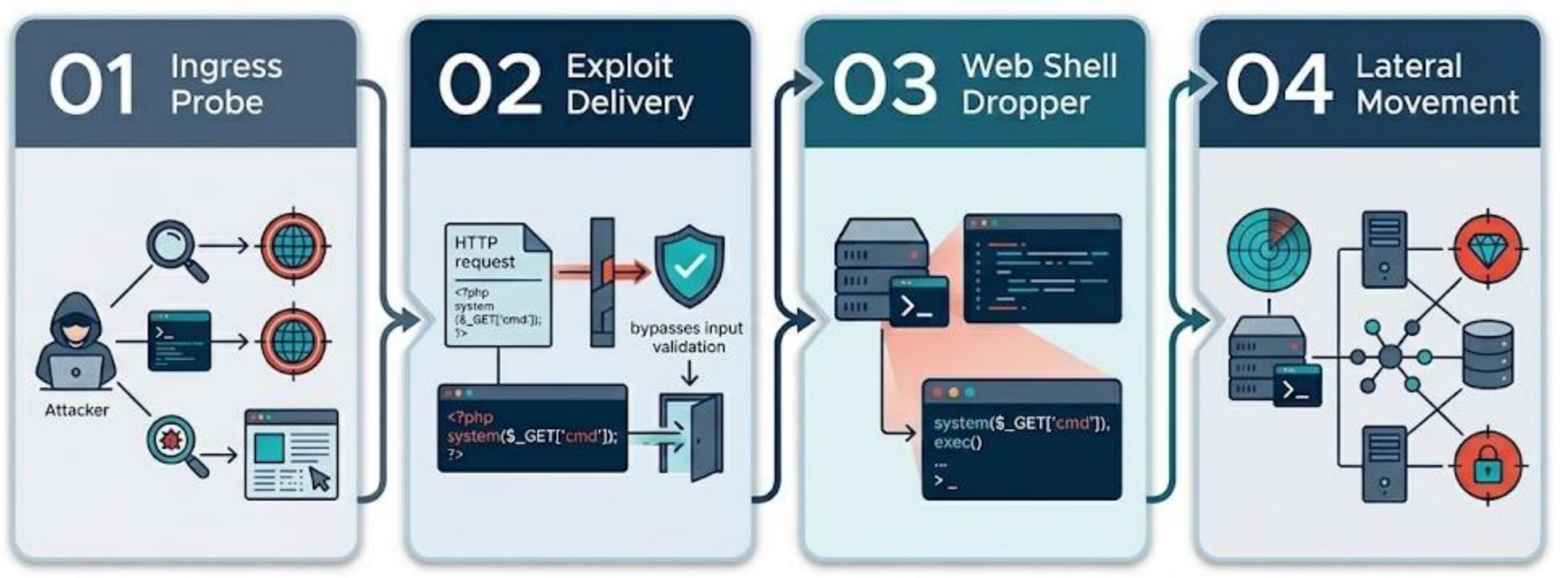
مجید ایرانپور

کارشناس امنیت اطلاعات

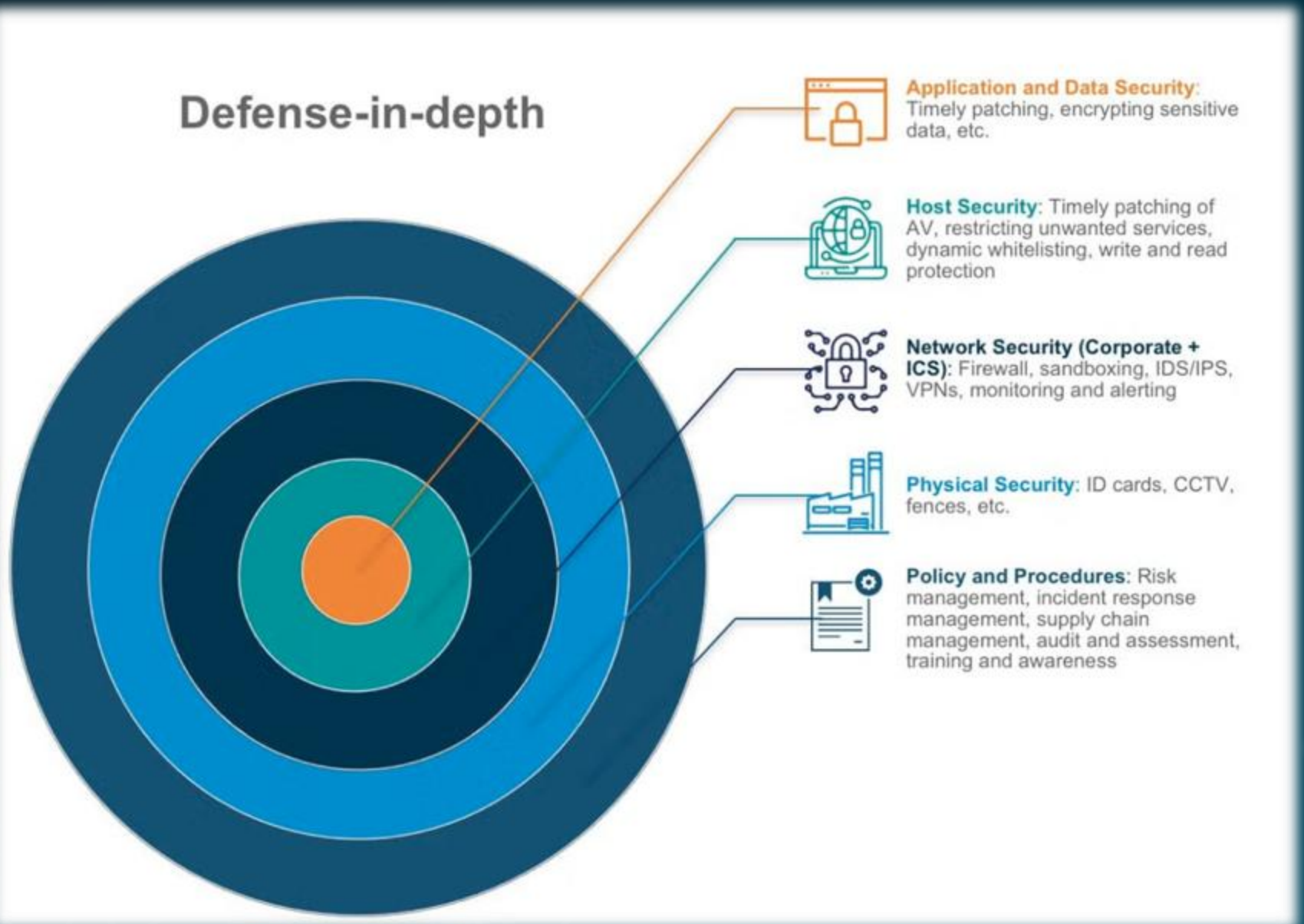
@br34k_p01nt

سناریو حمله

از یک رخداد تا یک تصمیم معماری:
چرا به Process Confinement نیاز داریم؟



دفاع در عمق


Defense-in-depth
Application and Data Security: Timely patching, encrypting sensitive data, etc.
Host Security: Timely patching of AV, restricting unwanted services, dynamic whitelisting, write and read protection
Network Security (Corporate + ICS): Firewall, sandboxing, IDS/IPS, VPNs, monitoring and alerting
Physical Security: ID cards, CCTV, fences, etc.
Policy and Procedures: Risk management, incident response management, supply chain management, audit and assessment, training and awareness

پس از مهار رخداد چه می پرسیم؟

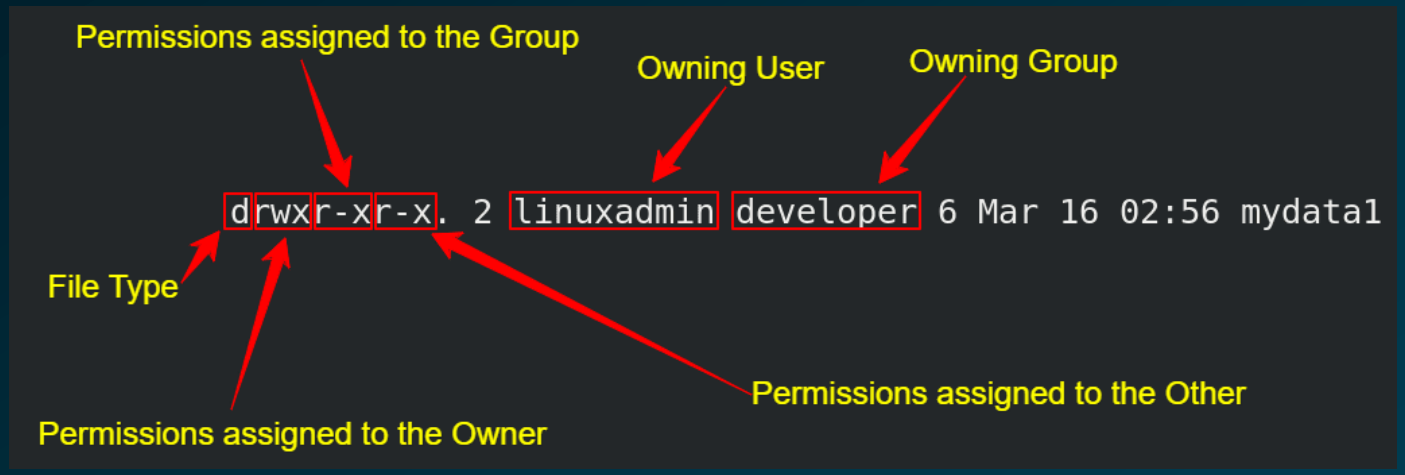


- میزبان ایزوله شد و سرویس بازیابی شد
- مشخص شد Process وب به منابعی فراتر از نیاز عملیاتی دسترسی داشته است
- قوانین Firewall بازنگری شد

اگر این Process دوباره آلوده شد، چطور مطمئن شویم فقط به
حداقل منابع لازم دسترسی دارد؟

اصل Least Privilege

DAC چه چیزی را کنترل می‌کند؟



Discretionary Access Control

مجوزهای متداول Linux بر پایه UID/GID، مالکیت و بیت‌های rwx

محدودیت در سناریوی ما

اگر Process با هویت مجاز به فایل دسترسی داشته باشد، کد اجراشده در همان Process نیز ممکن است از همان مجوز استفاده کند.

MAC، سیاستی فراتر از مالک فایل

Mandatory Access Control

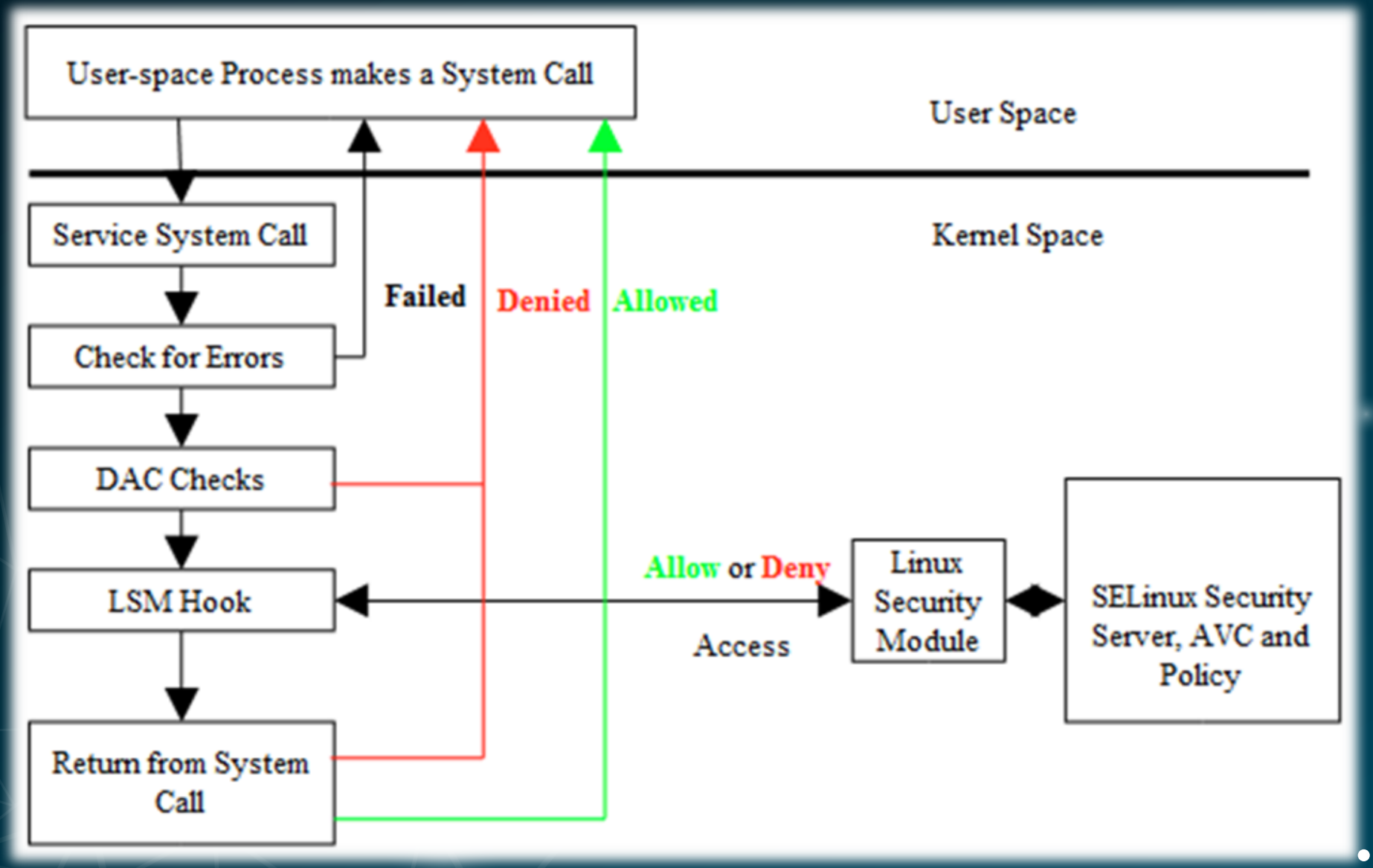
سیاست امنیتی مرکزی تعیین می‌کند کدام Subject تحت چه شرایطی می‌تواند به کدام Object دسترسی داشته باشد



ترکیب با DAC

برای دسترسی موفق، هم مجوز DAC باید اجازه دهد و هم سیاست MAC مانع نشود

SELinux


User-space Process makes a System Call
User Space
Service System Call
Kernel Space
Failed
Denied
Allowed
Check for Errors
DAC Checks
Allow or Deny
LSM Hook
Linux Security Module
SELinux Security Server, AVC and Policy
Access
Return from System Call

SELinux را با چهار مفهوم بفهمیم

Subject



فرایندی که درخواست دسترسی می‌دهد
مثلاً httpd

Object



منبعی که قرار است استفاده شود
فایل، دایرکتوری، پورت و...

Security Context



برچسب امنیتی متصل به Subject و Object

Policy



قواعدی که تعامل مجاز میان Context ها
را تعریف می‌کنند

مرز توانمندی‌ها را درست ببینیم

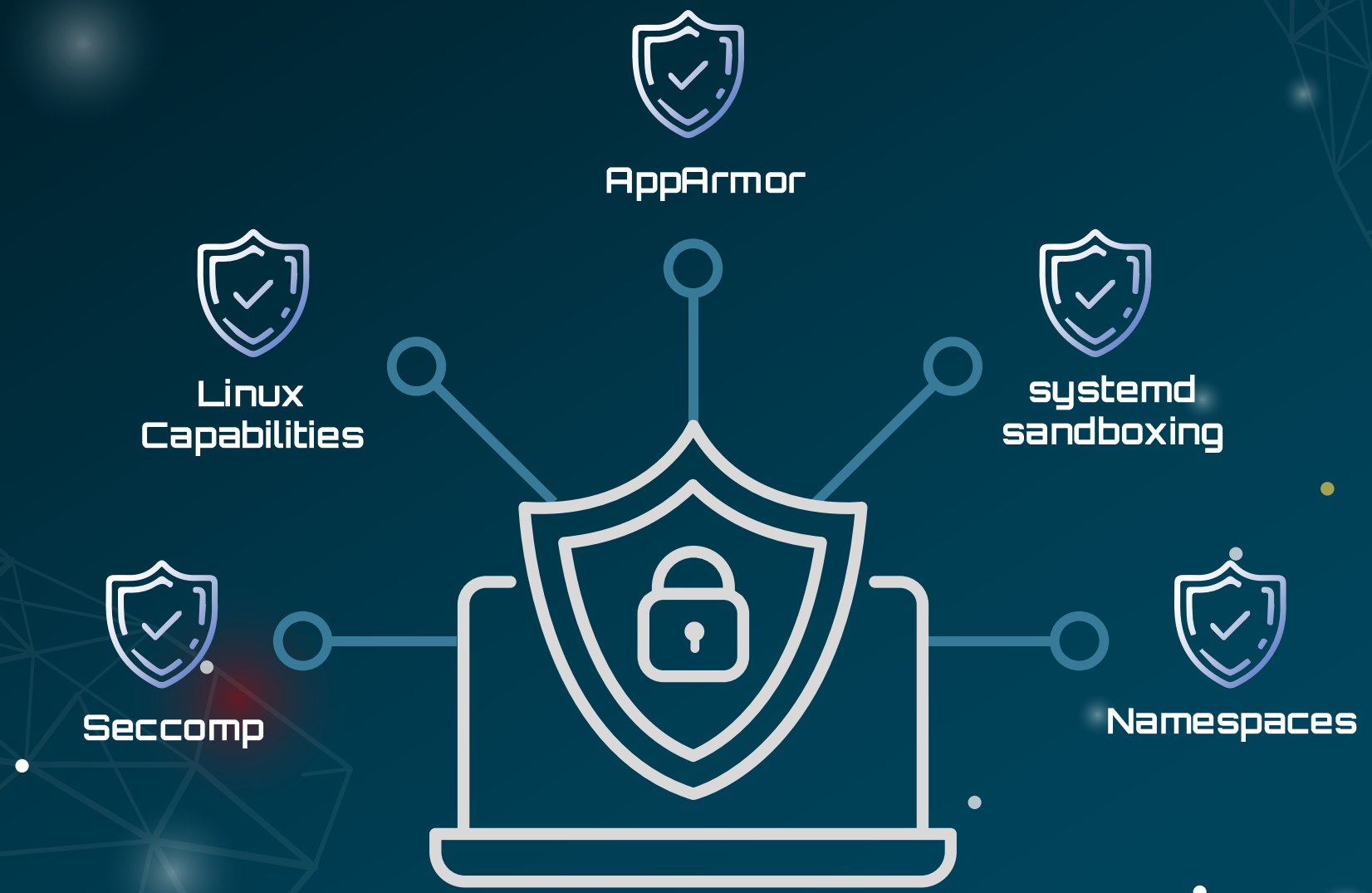
کمک می‌کند به...

- اعمال سیاست اجباری دسترسی
- محدود کردن تعامل Process با منابع
- ایجاد مرزهای امنیتی قابل ممیزی

جایگزین این‌ها نیست...

- Patch و رفع آسیب‌پذیری
- Secure coding و Hardening
- Network segmentation
- EDR، logging و ...

SELinux تنها ابزار دفاع لایه میزبان نیست





تشکر

@br34k_p01nt